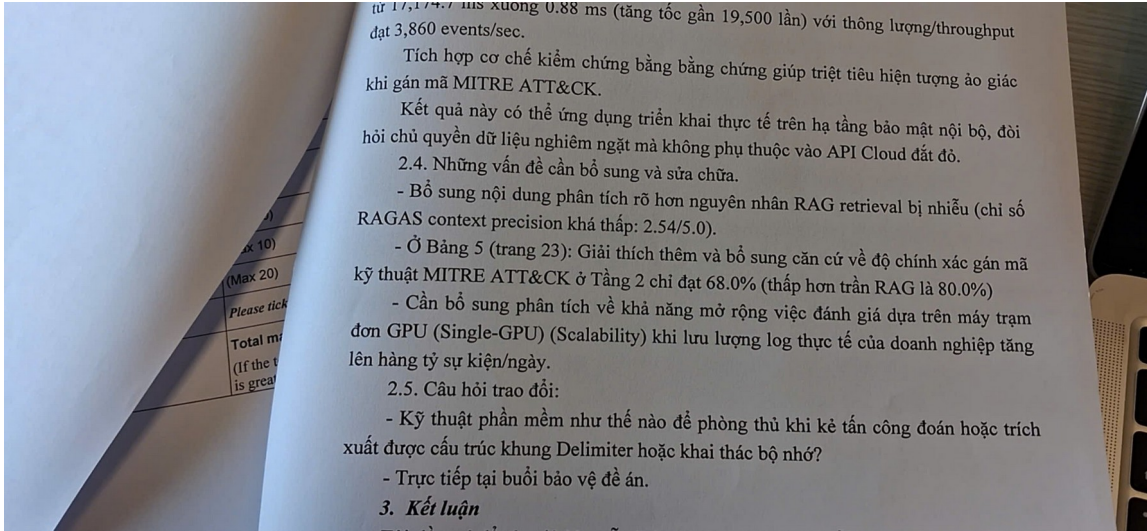


TỔNG HỢP HIỆU CHỈNH LUẬN VĂN & SLIDE BẢO VỆ THẠC SĨ

Học viên: Nguyễn Đức Bình — MSHV: 24MSE13183 — Lớp: MSE23HN

Đề tài: Kiến trúc nhận thức hai tầng cho phát hiện và phản ứng mối đe dọa an ninh mạng ứng dụng Agentic AI (SENTINEL)

I. Tóm tắt nội dung cần sửa trong report:



1. Giải thích Bảng 5: Khoảng lệch trần RAG (80.0%) và Toàn tuyến Tầng 2 (68.0%)

Bản chất: Do cơ chế Rào chắn neo chứng cứ (Evidence-Anchoring Guardrail) chủ động "khóa miệng" LLM để triệt tiêu ảo giác:

- Khi LLM đưa ra mã tấn công theo trí nhớ tham số nhưng mã đó **không có trong 5 tài liệu RAG nạp vào**, rào chắn lập tức hủy phán quyết, gán về N/A và chuyển người duyệt (AWAIT_HITL).
- Đây là sự đánh đổi có chủ đích: Em chấp nhận hy sinh 8.8% độ chính xác tự động danh định để đổi lấy 100% quyết định phát ra đều có bằng chứng truy nguyên, ngăn chặn hoàn toàn rủi ro AI ảo giác gây cấu hình sai tường lửa.

2. Phân tích nguyên nhân RAG retrieval bị nhiễu (RAGAS Context Precision: 2.54/5.0)

Bản chất: Do chiến lược "thà kéo thừa còn hơn bỏ sót" và tính không đồng nhất của kho tri thức kép (Dual-RAG):

- Hệ thống ưu tiên tuyệt đối cho Recall (đạt 82.2%) vì trong an ninh mạng, thà kéo thừa tài liệu để LLM lọc còn hơn bỏ lọt đòn tấn công (False Negative).
- Việc nạp gộp cả cẩm nang ứng cứu NIST lẫn kỹ thuật MITRE khiến ngữ cảnh bị loãng: Khi mô hình trọng tài (LLM Judge) chỉ chấm bài toán gán nhãn tấn công, toàn bộ tài liệu hướng dẫn xử lý của NIST bị coi là "nhiều".
- Em nhận diện đây là giới hạn của kiến trúc đơn đồ thị (Monolithic Context) hiện tại và đã nêu rõ ở Chương 5: Hướng phát triển tiếp theo là tách thành Đa tác tử (Multi-Agent) phân vai độc lập giữa pha gán nhãn (chỉ đọc MITRE) và pha xử lý sự cố (đọc NIST).

3. Phân tích khả năng mở rộng khi log tăng lên hàng tỷ sự kiện/ngày (Scalability Analysis)

Bản chất: Thiết kế phễu lọc hình nón: phần lớn việc nặng và rác đẩy cho CPU tốc độ cao dọn sạch, chỉ chừa lại đúng vài chục sự kiện "tinh hoa" mỗi giây cho GPU và LLM xử lý, thay đổi code đầu vào từ Python thành Rust/Go, dùng thuật toán Drain3 nén các log giống nhau hoặc template như nhau thành 1 sự kiện đại diện đỡ mất thời gian lên LLM phân tích (tránh DDoS hoặc bruteforce,...), backend thay bằng vLLM thay vì ollama, ...

Những chỗ đã update trong report:

Nội dung thay đổi	Vị trí trong luận văn (Page number & Section)
Giải trình Bảng 5 (68% vs 80%)	Trang 24: Nằm ngay bên dưới Table 5

Nội dung thay đổi	Vị trí trong luận văn (Page number & Section)
Phân tích RAGAS Context Precision 2.54	Trang 26: Nằm dưới Figure 9
Phân tích khả năng mở rộng khi log tăng lên hàng tỷ sự kiện/ngày	Trang 28–29: Nằm ở mục mới Section 4.4 (Infrastructure Scalability Analysis), ngay bên dưới Figure 10
Nhận diện giới hạn RAGAS Context Precision 2.54 & Đề xuất kiến trúc Multi-Agent	Trang 32–33: Nằm ở đoạn Limitations và Future Work của Chương 5

II. Tóm tắt nội dung cần sửa trong slide (Đồng bộ toàn tuyến):

1. Slide 3: Thực trạng & Nghịch lý LLM

- "Điểm phán quyết" → **"Điểm nghẽn duy nhất" (Bottleneck)**: Dùng chuẩn thuật ngữ kỹ thuật hệ thống SOC, đánh trúng vấn đề cốt lõi: log đổ về hàng triệu sự kiện nhưng bị tắc nghẽn ở con người.
- "Cảnh báo thật chìm trong nhiễu nền" → **"Phần lớn cảnh báo thô là báo giả; mỗi đe dọa thật dễ chìm trong nhiễu nền lưu lượng"**: Chuẩn hóa thực tế vận hành an ninh mạng hiện đại.
- "Tốc độ đường truyền" → **"Lưu lượng dòng sự kiện tốc độ cao"**: LLM không bị chậm do "dây mạng", mà nghẽn vì log đổ về dồn dập vượt quá năng lực tính toán và ngân sách VRAM.
- "Tiêu tốn GPU cho mọi sự kiện / Mong manh" → **"Lãng phí tài nguyên GPU cho toàn bộ lưu lượng thô; rủi ro Prompt Injection và rò rỉ dữ liệu"**: Nêu đích danh vector tấn công đặc thù AI.

2. Slide 4: Định hướng kiến trúc & Nguyên lý vận hành

- Chuẩn hóa nhãn sơ đồ SVG: RAW DATA → **DÒNG SỰ KIỆN ĐẦU VÀO (dữ liệu thô)**; FILTERED INTELLIGENCE → **TẦNG CAO HƠN (chỉ phân tích sự kiện phức tạp)**.
- Lược bỏ cụm từ "100% Air-gapped" → **Diễn giải "Vận hành cục bộ: 100% dữ liệu nằm trong hạ tầng nội bộ, không gửi ra đám mây bên ngoài"**: Tránh bẫy phản biện về định nghĩa cách ly vật lý quân sự, đảm bảo an toàn tuyệt đối trước Hội đồng.
- Mô tả **Tầng 1**: Khẳng định rõ: "Chặn nhiễu nền bằng chữ ký, thống kê và học máy nhẹ — 100% không gọi mô hình ngôn ngữ".

3. Slide 5: Bảng so sánh định vị hệ thống

- Dual-RAG + MITRE → **Dual-RAG (MITRE + NIST)**: Khớp trọn vẹn kiến trúc kép: MITRE ATT&CK giúp nhận diện kỹ thuật đòn đánh, NIST SP 800-61r2 cung cấp cẩm nang quy trình ứng cứu sự cố.
- "Rẻ trước, đắt sau" → **"Phân tầng theo chi phí tính toán (Filtration Economics)"**: Nâng tầm khẩu ngữ thành thuật ngữ khoa học hệ thống.
- "Ký liên kết từng bản ghi" → **"Chuỗi HMAC-SHA256: Ký băm liên kết chuỗi từng bản ghi"**: Nêu đích danh thuật toán chuẩn công nghiệp Hash Chaining bảo vệ tính toàn vẹn nhật ký.

4. Slide 6: Kiến trúc nhận thức hai tầng (Tầng 1 & Tầng 2)

- **Tầng 1 ghi rõ**: "Lọc dòng tốc độ cao bằng chữ ký tĩnh và học máy nhẹ, 100% không gọi LLM" — Tránh hiểu nhầm Tầng 1 là SIEM/SOAR thông thường.
- **Tầng 2 ghi rõ**: "Chỉ kích hoạt khi leo thang: Phân tích ngữ cảnh đòn tấn công mới, mỗi đe dọa Zero-day qua Dual-RAG và LLM" — Khẳng định vai trò nhận thức chuyên sâu của Agentic AI.

5. Slide 7: Tầng 1: Lá chắn tốc độ đường truyền

- "Mọi phán quyết ở tầng này đều rẻ" → **"Chi phí phán quyết tối thiểu"**: Chuẩn hóa văn phong học thuật.
- **Mô tả 3 chốt chặn**: "So khớp chữ ký tĩnh, cập nhật thống kê trực tuyến và phân loại học máy nhẹ — hoàn toàn không tiêu tốn tài nguyên mô hình sinh tạo" (WAF CRS 3.3 + Welford O(1) + LightGBM kẹp biên ±8σ).

6. Slide 8: Tầng 2: Tác tử nhận thức & Neo bằng chứng (Evidence Anchoring)

- **Nhãn sơ đồ nhánh rõ**: "Mã kỹ thuật: Hành động khớp RAG" và "N/A → HITL: nếu thiếu chứng cứ" — Làm rõ cơ chế chuyển giao Human-in-the-loop.

- "Luật sắt" → "Nguyên tắc kiểm soát: Triệt tiêu ảo giác bằng Neo bằng chứng (Evidence Anchoring) — không phán quyết mã kỹ thuật nào nếu thiếu chứng cứ đối sánh trong CSDL tri thức": Chuyển từ khẩu ngữ sang nguyên tắc an ninh AI chuẩn mực.

7. Slide 9: Lớp giáp bảo mật: Chống đối kháng & Pháp y

- **Bổ sung định danh chuẩn:** "1. Đóng gói dữ liệu phân định (Nonce Framing)" và "2. Niêm phong kiểm toán (HMAC Chain)".
- **Chuẩn hóa cột 2:** Vấn đề: "nguy cơ xóa hoặc can thiệp nhật ký pháp y"; Giải pháp: "ký băm liên kết chuỗi bằng HMAC-SHA256"; Hiệu lực: "chỉ ra chính xác vị trí bản ghi bị can thiệp khi chuỗi băm đứt gãy" (Chain of Custody).

8. Slide 10: Kết quả thực nghiệm

- **Đồng nhất định dạng nhãn có dấu hai chấm ":"** cho cả 4 chỉ số vàng: Tỷ lệ xả tải (97,5%), Độ trễ trung vị (0,88 ms), Cắt giảm tải chuyên viên (84,24% / bao phủ 95,0% mỗi đe dọa thật), Bảo mật toàn vẹn (100% kháng tiêm nhiễm & phát hiện giả mạo).

9. Slide 11: Kết luận & Hướng phát triển

- "100% Air-gapped" → "môi trường vận hành nội bộ (Air-gapped)": Thống nhất toàn tuyến với Slide 4.
- "tập log an ninh mạng trong nước" → "tập dữ liệu log an ninh mạng nội bộ": Tránh diễn đạt cảm tính.
- **Hướng phát triển:** "Triển khai kiến trúc đa tác tử chuyên biệt hóa, tăng tốc phục vụ với vLLM PagedAttention".

10. Slide 12: Bế mạc & Q&A

- "Phần trình bày đến đây là hết. Tiếp theo là demo hệ thống." → "Hệ thống sẵn sàng cho phần trình diễn thực nghiệm và giải đáp chuyên sâu": Khẳng định phong thái khoa học đỉnh đặc trước Hội đồng bảo vệ.

Bảng đối chiếu chi tiết các điểm sửa trên từng slide:

Vị trí	Nội dung trước đó (Bản gốc)	Nội dung sửa tương ứng (Bản chuẩn hóa) & Bản chất
Slide 3	1. Chuyên viên là điểm phán quyết duy nhất. Cảnh báo thật chìm trong nhiễu nền. 2. Chậm: suy luận LLM không đáp ứng nổi tốc độ đường truyền . 3. Tiêu tốn tài nguyên GPU cho mọi sự kiện. 4. Mong manh: dễ bị tiêm nhiễm qua log.	1. Chuyên viên là điểm nghẽn duy nhất trong quy trình (Bottleneck) . 2. Phần lớn cảnh báo thô là báo giả; mỗi đe dọa thật dễ chìm trong nhiễu nền lưu lượng. 3. Chậm: suy luận LLM không đáp ứng nổi lưu lượng dòng sự kiện tốc độ cao . 4. Lãng phí tài nguyên GPU cho toàn bộ lưu lượng thô. 5. Rủi ro tiêm nhiễm qua log (Prompt Injection) và rò rỉ dữ liệu. → Bản chất: Chuẩn hóa thuật ngữ kỹ thuật SOC; chỉ rõ bài toán điểm nghẽn con người và gánh nặng tính toán.
Slide 4	1. RAW DATA → FILTERED INTELLIGENCE. 2. Lọc dòng tốc độ cao: Chặn nhiễu bằng luật tĩnh và ML nhẹ. 3. Vận hành cục bộ (Air-gapped).	1. DÒNG SỰ KIỆN ĐẦU VÀO (dữ liệu thô) → TĂNG CAO HƠN (chỉ phân tích sự kiện phức tạp) . 2. Chặn nhiễu nền bằng chữ ký, thống kê và học máy nhẹ — 100% không gọi mô hình ngôn ngữ . 3. Vận hành cục bộ: 100% dữ liệu nằm trong hạ tầng nội bộ, không gửi ra đám mây bên ngoài . → Bản chất: Tránh bầy tranh luận cách ly vật lý quân sự; làm rõ triết lý lọc phân tầng 0-token.
Slide 5	1. Dual-RAG + MITRE 2. rẻ trước, đắt sau 3. ký liên kết từng bản ghi	1. Dual-RAG (MITRE + NIST) 2. Phân tầng theo chi phí tính toán (Filtration Economics) 3. Chuỗi HMAC-SHA256: Ký băm liên kết chuỗi từng bản ghi → Bản chất: Khớp tri thức kép; nâng tầm thuật ngữ học thuật; định danh chuẩn mật mã Hash Chaining.
Slide 6	1. Xử lý phần lớn lưu lượng. Không gọi LLM. 2. Chỉ kích hoạt khi leo thang. Suy luận LLM,	1. Lọc dòng tốc độ cao bằng chữ ký tĩnh và học máy nhẹ, 100% không gọi LLM .

Vị trí	Nội dung trước đó (Bản gốc)	Nội dung sửa tương ứng (Bản chuẩn hóa) & Bản chất
	Dual-RAG, ra phán quyết cuối, niêm phong HMAC.	2. Chỉ kích hoạt khi leo thang: Phân tích ngữ cảnh đòn tấn công mới, mối đe dọa Zero-day qua Dual-RAG và LLM. → Bản chất: Phân định ranh giới kiến trúc rõ ràng giữa lọc cơ học tốc độ cao và Agentic AI xử lý tấn công phức tạp.
Slide 7	1. Mọi phán quyết ở tầng này đều rẻ. 2. So khớp chữ ký, cộng dồn thống kê và một cây quyết định — không có suy luận sinh tạo.	1. Chi phí phán quyết tối thiểu 2. So khớp chữ ký tĩnh, cập nhật thống kê trực tuyến và phân loại học máy nhẹ — hoàn toàn không tiêu tốn tài nguyên mô hình sinh tạo. → Bản chất: Chuẩn hóa văn phong khoa học; khẳng định nguyên lý 0 Token LLM / 0 GPU VRAM / O(1) Memory.
Slide 8	1. Mã kỹ thuật có bằng chứng / N/A nếu thiếu bằng chứng 2. Luật sắt: không mã kỹ thuật nào được xuất ra nếu nó không có mặt trong tập chứng cứ vừa truy xuất.	1. Mã kỹ thuật: Hành động khớp RAG / N/A → HITL: nếu thiếu chứng cứ 2. Nguyên tắc kiểm soát: Triệt tiêu ảo giác bằng Neo bằng chứng (Evidence Anchoring) — không phán quyết mã kỹ thuật nào nếu thiếu chứng cứ đối sánh trong CSDL tri thức. → Bản chất: Xóa từ khẩu ngữ "luật sắt", dùng chuẩn Evidence Anchoring và làm rõ cơ chế Human-in-the-loop.
Slide 9	1. 1. Đóng gói dữ liệu phân định / 2. Niêm phong kiểm toán 2. xóa hoặc sửa dấu vết pháp y 3. ký liên kết chuỗi bằng HMAC-SHA256 4. một mắt xích gãy là đủ để chỉ ra đúng dòng bị sửa, chèn hoặc xóa giữa số	1. 1. Đóng gói dữ liệu phân định (Nonce Framing) / 2. Niêm phong kiểm toán (HMAC Chain) 2. Vấn đề: nguy cơ xóa hoặc can thiệp nhật ký pháp y 3. Giải pháp: ký băm liên kết chuỗi bằng HMAC-SHA256 4. Hiệu lực: chỉ ra chính xác vị trí bản ghi bị can thiệp khi chuỗi băm đứt gãy → Bản chất: Đưa thuật ngữ mật mã học chuẩn xác Nonce Framing & HMAC Chain; bảo toàn chuỗi hành trình chứng cứ (Chain of Custody).
Slide 10	1. Tỷ lệ xả tải. Tầng 1 và Cổng ML dọn xong nhiều nền, không cần gọi LLM. 2. Độ trễ trung vị. Giảm từ mức > 17.000 ms của LLM đơn tầng. 3. Cắt giảm tải chuyên viên trên 1.066 cảnh báo leo thang. Hàng đợi hoãn bao phủ 95,0% mỗi đe dọa thật. 4. Vô hiệu hóa tiêm nhiễm (trên 678 mẫu) và phát hiện sửa, chèn, xóa giữa số kiểm toán.	1. Tỷ lệ xả tải: Tầng 1 và Cổng ML dọn xong nhiều nền, không cần gọi LLM (97,5%). 2. Độ trễ trung vị: Rút ngắn từ > 17.000 ms của LLM đơn tầng xuống 0,88 ms. 3. Cắt giảm tải chuyên viên: Tự động hóa trên 1.066 cảnh báo leo thang; hàng đợi hoãn bao phủ 95,0% mỗi đe dọa thật (84,24%). 4. Bảo mật toàn vẹn: Vô hiệu hóa Prompt Injection (trên 678 mẫu) và phát hiện mọi can thiệp số kiểm toán (100%). → Bản chất: Đồng bộ cấu trúc nhãn ":" chuẩn mực; làm nổi bật 4 số liệu thực nghiệm định lượng then chốt.
Slide 11	1. tất cả trong môi trường 100% Air-gapped. 2. Tinh chỉnh trên tập log an ninh mạng trong nước. 3. Triển khai kiến trúc đa tác tử phân vai chuyên biệt, tăng tốc phục vụ bằng vLLM PagedAttention.	1. tất cả trong môi trường vận hành nội bộ (Air-gapped). 2. Tinh chỉnh trên tập dữ liệu log an ninh mạng nội bộ. 3. Triển khai kiến trúc đa tác tử chuyên biệt hóa , tăng tốc phục vụ với vLLM PagedAttention. → Bản chất: Thống nhất toàn tuyến về môi trường on-premise; dùng từ ngữ khoa học; nêu rõ hướng tối ưu hạ tầng.
Slide 12	Phần trình bày đến đây là hết. Tiếp theo là demo hệ thống.	Hệ thống sẵn sàng cho phần trình diễn thực nghiệm và giải đáp chuyên sâu. → Bản chất: Thay câu khẩu ngữ đời thường bằng phong thái báo cáo học thuật chuyên nghiệp, tự tin trước Hội đồng.